

Please help me compress the following content into a 40-second presentation script, and then provide suggestions for PowerPoint creation::

The fix is to make the SSO URL behave like a real one-time login ticket.

First, the token should be single-use. After the first successful redemption, later requests with the same URL should fail.

Second, it should be bound to the dashboard session that generated it. If the original dashboard session is gone, the SSO token should not work.

展开 ∨

40-Second Presentation Script

The fix is to make the SSO URL act like a real one-time login ticket.

First, the token should be single-use, so after one successful login, any reused URL immediately fails.

Second, the token should be tied to the original dashboard session, meaning it becomes invalid once that session ends.

Third, the token's lifetime should be very short, ideally only 30 to 60 seconds.

Fourth, the system should generate a new token for every click instead of reusing the same URL.

For stronger security, credentials should be removed from the URL entirely by using a POST request or a server-side session bridge.

PowerPoint Suggestions

Slide Layout

Use **1 slide only** for a 40-second explanation.

Recommended Structure

Title

Improving SSO Security

Main Content (use 5 short bullet points)

- Single-use token
- Bind token to session
- Short TTL: 30–60 seconds
- Rotate token every click
- Replace URL credentials with POST/session bridge

Visual Design Ideas

You could add:

- A **lock/security icon**
- A simple **flow diagram**:
 - User clicks SSO URL
 - Server validates token
 - Token expires immediately
- Use **red** to show the insecure old method and **green** for the secure solution

Animation Tips

- Reveal bullet points one by one
- Keep transitions simple (Fade)
- Avoid too much text

Speaking Tips

- Pause slightly after each “First, Second, Third...”
- Emphasize:
 - “single-use”
 - “30 to 60 seconds”
 - “removed from the URL entirely”



5995 report.docx

文档

Perform the same work as in section 3.2 of the diagram, providing design suggestions for the PowerPoint presentation and generating a 40-second speech script.

40-Second Presentation Script — Section 3.2 (E2 + E3)

Section 3.2 identifies two major transport security flaws in the app.

First, the app loads a webpage using plain HTTP instead of HTTPS, meaning attackers on the same network can read or modify the traffic.

Second, the app disables proper TLS protection by accepting every SSL certificate error through `sslErrorHandler.proceed()`.

In addition, the custom `HostnameVerifier` always returns true, so hostname validation is completely bypassed.

Together, these flaws allow attackers to perform man-in-the-middle attacks, inject malicious content, and impersonate trusted websites even after migrating to HTTPS.

PowerPoint Design Suggestions

Recommended Slide Title

3.2 E2 + E3: Cleartext URL and TLS Validation Bypass

Slide Layout (Single Slide)

Left Side — Vulnerabilities

Use 3 concise bullet points:

- HTTP used instead of HTTPS
- `sslErrorHandler.proceed()` accepts all certificates
- `HostnameVerifier.verify()` always returns true

Right Side — Attack Flow Diagram

Create a simple visual flow:

User App



HTTP / Invalid HTTPS Request



Attacker intercepts traffic



Fake certificate accepted



Malicious webpage injected

Use:

- Red arrows/icons for attack path
- Shield or warning icons for security issues

Visual Style Suggestions

Colors

- Red/orange for vulnerabilities
- Green only when mentioning secure HTTPS
- Dark background with light text works well for cybersecurity topics

Fonts

- Title: bold and large
- Keep bullet points short
- Highlight keywords like:
 - "HTTP"
 - "TLS"
 - "MITM attack"

Animation Suggestions

Use simple sequential animations:

1. Show HTTP issue
2. Show SSL bypass
3. Show HostnameVerifier issue
4. Reveal attack flow

Avoid complicated transitions.

Speaking Tips

- Emphasize:
 - "plain HTTP"
 - "accepts every SSL error"
 - "man-in-the-middle attack"

- Speak slightly slower when explaining the attack impact.
- Point to the diagram while explaining how the attacker intercepts traffic.

